

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-06-12 · Source SHA: 61ed8c3140d76e3a19a88954e834d39c9f7635fb

Summary

Metric	Count
Total CVEs found	13
CRITICAL dependencies	3
HIGH dependencies	2
MEDIUM dependencies	1
LOW dependencies	3
Outdated dependencies	8
License violations	1
Supply-chain alerts	2

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.17.1
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2021-44228	10.0	CRITICAL	2.17.1
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.13.4.2
com.google.guava:guava	24.1.1-jre	CVE-2018-10237	5.9	MEDIUM	32.0.0-jre
mysql:mysql-connector-java	8.0.30	— (GPL-2.0 license violation)	—	MEDIUM	8.0.33

All CVEs

CVE	Dependency	CVSS	Severity	Description
CVE-2021-44228	log4j-core, log4j-api	10.0	CRITICAL	Log4Shell: JNDI lookup RCE via log message parameters
CVE-2021-45046	log4j-core	9.0	CRITICAL	Bypass of CVE-2021-44228 fix; RCE/DoS via thread context
CVE-2019-14379	jackson-databind	9.8	CRITICAL	Polymorphic typing RCE gadget chain (ehcache)
CVE-2019-14540	jackson-databind	9.8	CRITICAL	Polymorphic typing RCE gadget chain (HikariCP)
CVE-2020-36518	jackson-databind	7.5	HIGH	JsonNode JDK serialization 2 GB heap exhaustion (DoS)
CVE-2022-42003	jackson-databind	7.5	HIGH	Deep wrapper array nesting resource exhaustion (DoS)
CVE-2019-12384	jackson-databind	5.9	MEDIUM	Polymorphic typing information disclosure (logback gadget)
CVE-2021-44832	log4j-core	6.6	MEDIUM	RCE via JDBC Appender in attacker-controlled logging config

CVE-2021-45105	log4j-core	5.9	MEDIUM	Uncontrolled recursion DoS via self-referential lookups
CVE-2018-10237	guava	5.9	MEDIUM	Unbounded memory allocation DoS via deserialization
CVE-2023-2976	guava	5.5	MEDIUM	Insecure temp directory creation (local info disclosure)
CVE-2020-8908	guava	3.3	LOW	Insecure createTempDir() local information exposure

Outdated dependencies (no CVE)

Dependency	Current	Latest	Gap
commons-io:commons-io	2.4	2.18.0	14 minor versions
org.apache.commons:commons-lang3	3.4	3.17.0	13 minor versions
org.junit.jupiter:junit-jupiter	5.10.2	5.13.0	3 minor versions

License violations

Dependency	License	Issue
mysql:mysql-connector-java	GPL-2.0	Copyleft license incompatible with commercial/permissive projects; contamination risk

Supply-chain alerts

CRITICAL — Typosquatted dependency detected. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core:jackson-databind`. The groupId is missing the letters "er" — a classic typosquatting pattern. This coordinate does not exist on Maven Central and fails to resolve. A real package at this coordinate could execute arbitrary code at build or runtime. **Remove immediately.**

HIGH — Untrusted HTTP repository. `http://insecure-mirror.example.net/maven2` is declared as a Maven repository using plain HTTP (no TLS). This enables man-in-the-middle artifact injection attacks where a network attacker can substitute malicious JARs for legitimate ones at download time. **Remove or replace with a verified HTTPS endpoint. Enforce artifact checksums and signatures.**